

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-16 16:55 WIB

Top 5 Highlights

- When AI gets a body, it inherits an attack surface
- New Spirals ransomware encrypts victim network in under 24 hours
- Tenable One unifies code risks with enterprise exposure data
- F5 Patches Multiple NGINX, BIG-IP Vulnerabilities
- The executive profile your security team isn't defending

Threat Intelligence (10)

01. Hidden Infrastructure Exposed: ANY.RUN Reveals Hijacked Gov Websites Delivering Malware

An original threat intelligence investigation uncovering how trusted government infrastructure became an attack channel, placing banking organizations and public-sector systems at risk while revealing previously undocumented infrastructure relationships and actionable mitigation guidance for security leaders. ANY.RUN analysts have uncovered an active Phanto...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://any.run/cybersecurity-blog/phantomenigma-research/>

02. Old UEFI Shims Expose Systems to Secure Boot Bypass

Signed by Microsoft, the vulnerable UEFI shim bootloaders could be abused on any system, regardless of the OS. The post Old UEFI Shims Expose Systems to Secure Boot Bypass appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/old-uefi-shims-expose-systems-to-secure-boot-bypass/>

03. ISC Stormcast For Thursday, July 16th, 2026 <https://isc.sans.edu/podcastdetail/10010>, (Thu, Jul 16th)

ISC Stormcast For Thursday, July 16th, 2026 <https://isc.sans.edu/podcastdetail/10010>, (Thu, Jul 16th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33160>

04. Unpacking the AsyncAPI npm supply chain compromise and import-time payload delivery

Threat actors compromised AsyncAPI packages and weaponized trusted CI/CD workflows to distribute malware through npm. This analysis breaks down the attack chain, payload delivery, and recommended defenses. The post Unpacking the AsyncAPI npm supply chain compromise and import-time payload delivery appeared first on Microsoft Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/07/15/unpacking-asyncapi-npm-supply-chain-compromise-import-time-payload-delivery/>

05. TELEPUZ: a modular MaaS malware spreading via CLICKFIX-VIDAR chains

TELEPUZ is a modular malware that emerged through CLICKFIX-VIDAR attacks in April. We reverse-engineered it to show you the infrastructure and evasion techniques that matter.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.elastic.co/security-labs/telepuz-maas-malware-clickfix>

06. The npm Threat Landscape: Attack Surface and Mitigations (Updated July 15)

Unit 42 analyzes npm supply chain evolution post-Shai Hulud. Discover wormable malware, CI/CD persistence, multi-stage attacks and more. The post The npm Threat Landscape: Attack Surface and Mitigations (Updated July 15) appeared first on Unit 42 .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://unit42.paloaltonetworks.com/monitoring-npm-supply-chain-attacks/>

07. Forgotten Bootloaders Expose Secure Boot Blind Spot

Nearly a dozen vulnerable and now revoked UEFI shim bootloaders remained trusted for years, giving attackers a path to bypass Secure Boot.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyber-risk/forgotten-bootloaders-expose-secure-boot-blind-spot>

08. TuxBot v3 Evolution Shows Signs of LLM-Assisted IoT Botnet Development

Cybersecurity researchers have disclosed details of a previously unreported Internet-of-Things (IoT) botnet framework dubbed TuxBot v3 Evolution that shows signs of being developed with assistance from a large language model (LLM), albeit with not so successful results. "While the AI complied with their request to generate botnet code, it included a safety...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/tuxbot-v3-evolution-shows-signs-of-llm.html>

09. Google Gemini CLI abused as a hacking agent, malware botnet operator

A Russian-speaking threat actor known as "bandcampro" used Google's open-source Gemini CLI AI tool as a hacking agent and to operate a small-scale botnet. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/google-gemini-cli-abused-as-a-hacking-agent-malware-botnet-operator/>

10. Operation Fake KickOff: Attackers Abuse Recruiters and SaaS to Harvest Work Credentials

Intel 471 investigated an ongoing, multi-stage phishing operation that systematically abuses legitimate software-as-a-service (SaaS) sales and marketing, and cloud platforms to orchestrate corporate credential theft.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.intel471.com/blog/operation-fake-kickoff-attackers-abuse-recruiters-and-saas-to-harvest-work-credentials>

Latest Vulnerabilities (10)

01. When AI gets a body, it inherits an attack surface

Most security leaders I know working on AI robotics are being shown the same kind of video. A humanoid folds a shirt, sorts a bin, walks a warehouse aisle and a vendor uses the clip to move an embodied AI system from pitch to purchase order. Someone then has to sign off. Robot demos create procurement momentum before security teams receive the artifacts nee...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoononline.com/article/4197463/when-ai-gets-a-body-it-inherits-an-attack-surface.html>

02. Tenable One unifies code risks with enterprise exposure data

Tenable has announced the expansion of the Tenable One Exposure Management Platform, unifying application security risks with all other exposure data. By integrating static code vulnerability data, Tenable One delivers complete, code-to-runtime visibility across the entire attack surface. Security teams have long struggled with a code security problem where...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.helpnetsecurity.com/2026/07/16/tenable-expands-one-exposure-management-platform/>

03. F5 Patches Multiple NGINX, BIG-IP Vulnerabilities

Attackers could exploit the bugs to modify configurations, terminate or restart processes, cross security boundaries, leak memory, and execute code. The post F5 Patches Multiple NGINX, BIG-IP Vulnerabilities appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/f5-patches-multiple-nginx-big-ip-vulnerabilities/>

04. The executive profile your security team isn't defending

A few years ago, I was retained to conduct a digital risk review for the chief executive of a mid-sized financial services firm. The brief was standard. Assess what was publicly available about the executive, identify exposure and advise on remediation. The AI tools I used completed the substantive reconnaissance in under ten minutes. What came back was a S...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4197460/the-executive-profile-your-security-team-isnt-defending.html>

05. US Launches Gold Eagle to Coordinate AI-Driven Vulnerability Management

The White House announced Gold Eagle to help accelerate the discovery, prioritization and patching of flaws found by AI

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.infosecurity-magazine.com/news/us-gold-eagle-ai-vulnerability/>

06. Microsoft makes Windows SSO prompts easier to manage

Microsoft is introducing a new registry-based policy that lets IT administrators automatically accept Windows SSO permissions on Windows 11 versions 24H2 and 25H2 devices managed with Microsoft Entra ID. Users with personal Microsoft accounts and devices outside policy-managed environments will continue to receive SSO permission prompts. Admin control for S...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/16/windows-ss-policy-admin-control/>

07. OpenAI's GPT-Red Automates Prompt Injection Testing to Harden GPT-5.6 Sol

OpenAI has disclosed details of GPT-Red, an internal automated red-teaming model that scales prompt injection vulnerability discovery with an aim to fix issues before the tools are deployed widely. "GPT-Red is a strong red-teamer, and our previous models are highly vulnerable to its prompt injection attacks," the artificial intelligence (AI) company said. "...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/openai-gpt-red-automates-prompt.html>

08. Zoom Patches Critical Windows Flaw That Could Enable Account Takeover

Zoom has released security updates for a critical security flaw impacting Zoom Workplace for Windows that could facilitate account takeover. The vulnerability, tracked as CVE-2026-53412 (CVSS score: 9.8), affects Zoom Desktop Client for Windows, Zoom VDI Client for Windows, and Zoom Meeting SDK for Windows. "Improper Input Validation in Zoom Desktop Client...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/zoom-patches-critical-windows-flaw-that.html>

09. Flaw surge fuels need for CISOs to rethink vulnerability management

Security experts are calling on enterprises to revise their vulnerability management strategies and move towards "just in time" patching in response the increased pace of vulnerability exploitation. Attackers are turning to AI to increase the rate of vulnerability exploitation and supply chain compromise so that traditional forms of vulnerability management...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4196435/flaw-surge-fuels-need-for-cisos-to-rethink-vulnerability-management.html>

10. Nightmare Eclipse Drops 'LegacyHive' Windows Zero-Day

The researcher stripped the proof-of-concept (PoC) exploit to prevent immediate exploitation of the vulnerability. The post Nightmare Eclipse Drops 'LegacyHive' Windows Zero-Day appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/nightmare-eclipse-drops-legacyhive-windows-zero-day/>

Data Breach & Cybercrime (10)

01. New Spirals ransomware encrypts victim network in under 24 hours

A new ransomware actor called Spirals completed a corporate intrusion, from initial access to data theft and encryption, in less than 24 hours. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/new-spirals-ransomware-encrypts-victim-network-in-under-24-hours/>

02. Police take down investment fraud network that stole €100 million a month

Dutch police, working alongside Belgian authorities and Europol, have dismantled a major criminal network accused of operating a global investment fraud scheme through dozens of fraudulent call centers. Investigators estimate the organization generated more than €100 million a month by targeting victims in multiple countries. The group operated around 20 ca...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/16/dutch-police-investment-fraud-ring-dismantled/>

03. Police Disrupt a €140M Cyber Fraud Ring in Spain

Iberian hackers carried out a variety of cyberattacks and laundered the winnings through complex financial networks.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/threat-intelligence/police-disrupt-140m-euro-cyber-fraud-ring-spain>

04. Ransom demands are down, email is the top way attackers get in

An employee opens an email that looks like any other, clicks a link, and gives up a password without noticing. A stolen login opens a door deeper in the network. Files stop opening a few days later. That chain now sits at the front of most ransomware cases. Malicious email and phishing together account for half of all incidents, based on a survey of 2,158 I...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.helpnetsecurity.com/2026/07/16/sophos-state-of-ransomware-2026/>

05. Companies keep getting breached by vulnerabilities they already knew about

Scanning tools have gotten good at their work. Organizations now find more weaknesses across more of their systems than at any earlier point in the industry's history. A survey from the security firm Vicarius points to a gap that opens after that discovery, in the work of assigning, approving, deploying, and confirming a fix. The company surveyed 300 IT and...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/16/ciso-vulnerability-remediation-gap/>

06. Dutch police bust investment fraud ring stealing over €100 million

The Dutch Police announced the arrest of multiple individuals suspected of being part of an international investment fraud scheme estimated to have tens of thousands of victims. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/dutch-police-bust-investment-fraud-ring-stealing-over-100-million/>

07. Europe built the world's strongest privacy law. WhatsApp just found the gap it doesn't cover.

WhatsApp usernames boost privacy but weaken identity verification, raising fraud risks.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/perspective/europe-built-the-worlds-strongest-privacy-law-whatsapp-just-found-the-gap-it-doesnt-cover>

08. U.S. sanctions VPN provider and cryptor seller for aiding ransomware gangs

The sanctioned entities include First VPN Service (1VPNS), a virtual private network provider, and its administrator Dmytro Rashevskyi.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/u-s-sanctions-vpn-provider-and-cryptor-seller-for-aiding-ransomware-gangs>

09. Spanish police dismantle €140 million investment fraud and BEC cybercrime ring

The cybercrime network operated on an industrial scale, utilizing at least 800 bank accounts and 120 business accounts, with 67 external accomplices acting as money mules.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/spanish-police-dismantle-e140-million-investment-fraud-and-bec-cybercrime-ring>

10. US Charges Russian Individuals and Firms for Running Cybercrime Services

The suspects and their companies were previously sanctioned by the United States and its allies. The post US Charges Russian Individuals and Firms for Running Cybercrime Services appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/us-charges-russian-individuals-and-firms-for-running-cybercrime-services/>